



audatis MANAGER

Vorstellung Compliance + ISMS

A. Ruben

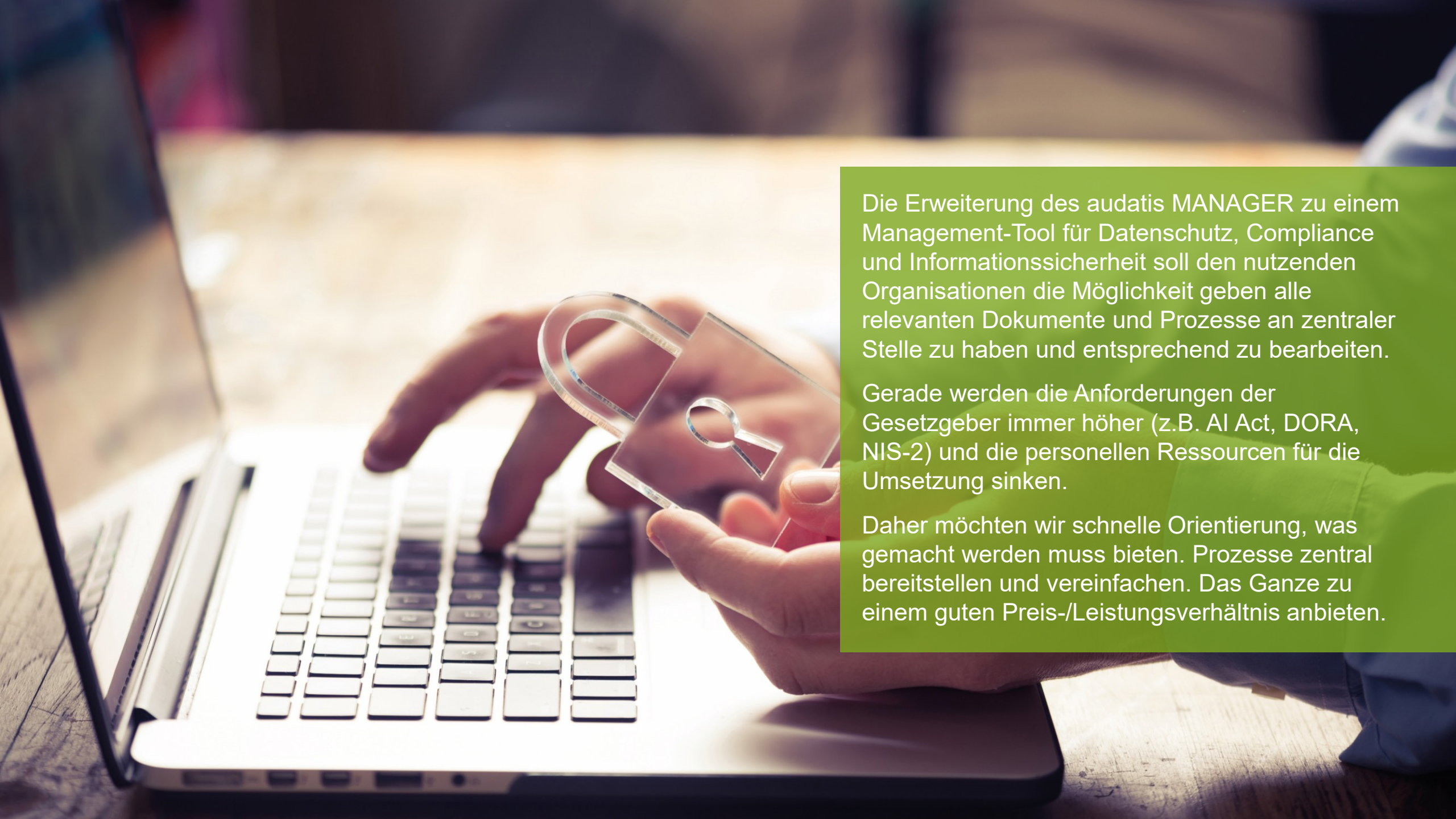
Der audatis MANAGER wird von der audatis Services GmbH in Herford entwickelt und im Rechenzentrum der Plusserver GmbH in Köln betrieben.

Seit 2023 sind wir ISO 27001 zertifiziert und können so von der Entwicklung bis zum Rechenzentrumsbetrieb die komplette Sicherheitskette abdecken.



Management
System
ISO/IEC 27001:2013

www.tuv.com
ID 9000030521



Die Erweiterung des audatis MANAGER zu einem Management-Tool für Datenschutz, Compliance und Informationssicherheit soll den nutzenden Organisationen die Möglichkeit geben alle relevanten Dokumente und Prozesse an zentraler Stelle zu haben und entsprechend zu bearbeiten.

Gerade werden die Anforderungen der Gesetzgeber immer höher (z.B. AI Act, DORA, NIS-2) und die personellen Ressourcen für die Umsetzung sinken.

Daher möchten wir schnelle Orientierung, was gemacht werden muss bieten. Prozesse zentral bereitstellen und vereinfachen. Das Ganze zu einem guten Preis-/Leistungsverhältnis anbieten.

Agenda

1. **Warum Compliance + ISMS?**
2. **Vorbereitungen**
3. **Compliance-Register**
4. **KI-Compliance**
5. **Geschäftsprozesse**
6. **Ereignisse und Sicherheitsvorfälle**
7. **Risikomanagement**
8. **ISMS-Compliance**
9. **Fragen und Antworten**

Warum Compliance +
ISMS?

Warum Compliance + ISMS?

1. Compliance-Anforderungen erfüllen

Unternehmen werden durch zahlreiche Gesetze, eigene Interessen, vertragliche Vereinbarungen oder Interessen von Stakeholder wie Zertifizierungsstellen, Kunden, Gesellschafter, etc. vor die Herausforderung gestellt, immer mehr Anforderungen zu erfüllen.

- Wie behält man da den Überblick, was für die eigene Organisation wichtig ist und gilt?
- Wie vergisst man nicht, sich bei Änderungen mit diesen rechtzeitig zu beschäftigen?
- Wie kann man die Einhaltung im besten Fall sogar nachweisen?
- Einige Normen fordern spätestens mit einer Zertifizierung ein Compliance-Register (ISO 9001 oder 27001) wie erstellt man dieses?

2. Informationssicherheits-Managementsystem (ISMS) aufbauen und betreiben

Wer ein ISMS nachweisen möchte oder muss, kommt nicht an der Unterstützung durch zentrale Prozesse und Dokumentation vorbei. Das kann man zum Schönheitswettbewerb werden lassen oder pragmatisch umsetzen.

- Was benötige ich für ein ISMS zur Erfüllung der Compliance mit meinem Standard?
- Wie kann ich zwischen Datenschutz- und Informationssicherheitsmanagement die größtmögliche Schnittstelle abbilden und damit den Aufwand reduzieren?

Warum Compliance + ISMS?

3. KI-Systeme einsetzen und Compliance-Anforderungen erfüllen

Der AI Act der EU (KI-Verordnung) fordert je nach Risikoklasse eines KI-Systems und der eigenen Rolle als Organisation zahlreiche Nachweise, Umsetzungen, Pflichten, welche zu erfüllen sind.

- Wie behält man da den Überblick, was für die eigene Organisation wichtig ist und gilt?
- Wie kann man die Umsetzung dokumentieren?

Auf diese Fragen werden wir in den nächsten 45 Minuten eingehen.

Vorbereitungen

1. Bestellung auslösen

Der Systemadministrator eines Mandanten kann entweder in den „Rechnungs- und Lizenzdaten“ im Hauptmandanten über den Reiter „Umfang erweitern“ oder in den „Lizenzdaten“ eines Untermantanten die Bestellung des Compliance + ISMS Erweiterungs-Pakets durchführen:

Compliance + ISMS Erweiterung bestellen: ☐ Ja, hiermit bestätige ich die kostenpflichtige Bestellung der Compliance + ISMS Erweiterung für monatlich 29,00 EUR (netto) für diesen Mandanten.

☒ Compliance + ISMS Erweiterung kostenpflichtig bestellen

Das Paket beinhaltet 10 zusätzliche Benutzer und 6 neue Module.

2. Risikoeinstellung für ISMS und KI anlegen

Es muss je eine Risikoeinstellung für ISMS und KI existieren und aktiviert sein, um in den neuen Modulen damit arbeiten zu können. Dies kann in den „Risikoeinstellungen“ erfolgen, in welcher die Einträge für beide Typen angelegt werden müssen:

Einstellungen:

- Benutzerverwaltung
- Mandanteneinstellungen
- Rechnungs- und Lizenzdaten
- Risikoeinstellungen
- Gelöschte Daten
- Organisationseinheiten
- Textbausteine

Bezeichnung	Typ	Aktiv
Risikomanagement (KI)	Risikomanagement (KI)	Ja
Risikomanagement (ISMS)	Risikomanagement (ISMS)	Ja

Compliance-Register

Compliance-Register

Dieses neue Modul dient als internes „Rechtskataster“, um alle Gesetze und anderen Compliance-Anforderungen, welche für Ihr Unternehmen gelten, zu dokumentieren, im Blick zu behalten und entsprechend umsetzen zu können. Bisher haben Sie dies vielleicht in einer Word-Datei oder Excel-Liste dokumentiert und können nun stattdessen dieses Modul mit Erinnerungsfunktion nutzen.

1. Neuen Eintrag anlegen

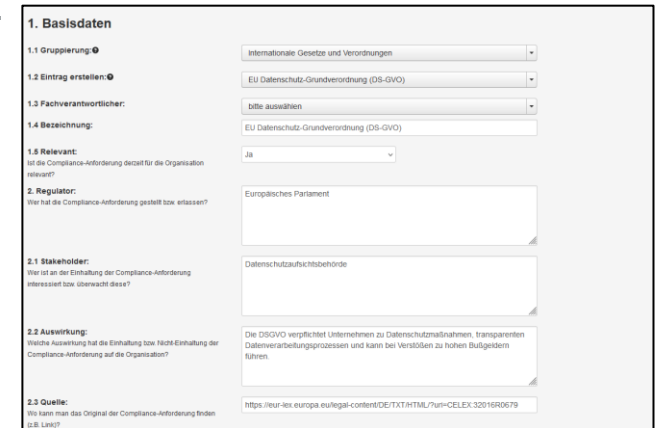
Als erstes muss eine Gruppierung ausgewählt werden. Anschließend kann ein eigener Eintrag erstellt oder eine „Vorlage“ ausgewählt werden (bspw. DS-GVO). Im Falle einer Vorlage werden die Felder automatisch ausgefüllt.

2. Alle Punkte (falls gewünscht) anpassen

3. Prüfung

Sobald ein Datensatz Ihren Anforderungen entspricht, kann dieser wie bisher zur Prüfung freigegeben werden. Die Prüfung bedeutet in diesem Fall die Überprüfung des Gesetzes auf die Relevanz oder schon berücksichtigten Anforderungen. Dabei muss womöglich die Quelle überprüft werden. Hier kann auch eine erneute Prüfung festgelegt werden (bspw. nach einem Jahr), um zu kontrollieren, ob der angelegte Datensatz noch aktuell ist.

4. Export → CSV-Datei



1. Basisdaten

1.1 Gruppierung: Internationale Gesetze und Verordnungen

1.2 Eintrag erstellen: EU Datenschutz-Grundverordnung (DS-GVO)

1.3 Fachverantwortlicher: bitte auswählen

1.4 Bezeichnung: EU Datenschutz-Grundverordnung (DS-GVO)

1.5 Relevant: Ja

2. Regulator: Europäisches Parlament

2.1 Stakeholder: Datenschutzbehörde

2.2 Auswirkung: Die DSGVO verpflichtet Unternehmen zu Datenschutzmaßnahmen, transparenten Datenverarbeitungsprozessen und kann bei Verstößen zu hohen Bußgeldern führen.

2.3 Quelle: <https://eur-lex.europa.eu/legal-content/DE/TXT/HTML/?uri=CELEX:32016R0679>

KI-Compliance

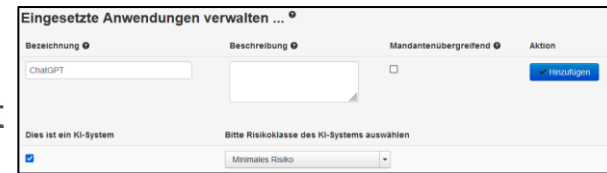
KI-Compliance

Dieses neue Modul dient dazu die Anforderungen und Pflichten aus der EU KI-Verordnung an KI-Systeme zu ermitteln und deren Umsetzung zu dokumentieren.

1. Anwendung anlegen

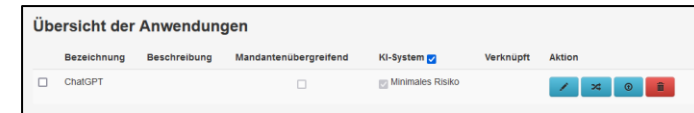
Im Modul „Daten- und IT-Inventarisierung“ können nun Anwendungen als „KI-System“ angelegt bzw. markiert werden. Dies muss als erster Schritt erfolgen.

Durch das Setzen des Hakens wird an dieser Stelle nach den KI-Systemen gefiltert.



2. Neue KI-Compliance anlegen

Dabei gilt herauszufinden: wie konform sind meine KI-Anwendungen? Sie können pro Datensatz eine Risikoklasse auswählen, die Rolle(n) Ihrer Organisation in Bezug auf die KI-Systeme auswählen und verschiedene IT-Anwendungen mit einbeziehen.



Bezeichnung	Beschreibung	Mandantenübergreifend	KI-System	Verknüpft	Aktion
☐ ChatGPT		☐	☒ Minimales Risiko		   

3. Beschreibung und Pflichten ausfüllen

4. Datensatz zur Prüfung einreichen

Geschäftsprozesse

Dieses Modul gleicht dem bereits existierenden „Verzeichnis der Verarbeitungstätigkeiten“ und ist mit diesem auch verknüpft. So wird jede angelegte Verarbeitungstätigkeit auch automatisch im Modul „Geschäftsprozesse“ als Datensatz angelegt. Dieser Datensatz wird in beiden Modulen angezeigt, solange dieser als Prozess mit personenbezogenen Daten definiert ist. Ohne personenbezogene Daten verschwindet der Datensatz aus dem „Verzeichnis der Verarbeitungstätigkeiten“.

Somit können jetzt auch Geschäftsprozesse ohne Personenbezug verwaltet werden bspw. Produktionsprozess mit vertraulichen Informationen, welche für das ISMS relevant sind.

1. Neuen Geschäftsprozess anlegen und Typ bestimmen

2. Ausfüllen des Datensatzes

Bei einem Datensatz ohne personenbezogenen Daten sind beim Ausfüllen des Geschäftsprozesses weniger Felder auszufüllen als bei den Verarbeitungstätigkeiten, da in einem Geschäftsprozess nicht alle aus der DS-GVO relevanten Angaben abgefragt werden müssen. Dabei werden die identischen Felder jedoch in beiden Modulen synchronisiert.

3. Prüfung

Ereignisse und Sicherheitsvorfälle

Ereignisse und Sicherheitsvorfälle

Dieses neue Modul ist eine Vorstufe für das bereits bekannte Modul „Datenschutz- und Sicherheitsvorfälle“. Hier werden also erst einmal Ereignisse gemeldet, welche dann nach einer Evaluation eventuell als Datenschutz- und Sicherheitsvorfall weiterbearbeitet werden.

1. Ereignis wird gemeldet

2. Bearbeitung des Datensatzes

3. Prüfung

Bei der Prüfung können betroffene Anwendung aus den Geschäftsprozessen ausgewählt werden. In der Prüfung muss ansonsten eine Risikobewertung durchgeführt werden und am Ende entschieden werden, ob es sich um einen Datenschutz- und Sicherheitsvorfall handelt und dieser weiterbehandelt werden muss.

Übergabe für weitere Schritte •

Es liegt vermutlich ein Datenschutz- und Sicherheitsvorfall vor, welcher weiter behandelt und geprüft werden muss.

→ In diesem Fall wird automatisch ein Datensatz im Modul „Datenschutz- und Sicherheitsvorfälle“ angelegt. Anschließend müssen beide Datensätze in den beiden Modulen separat behandelt werden. (Bspw. Kann der Datensatz in „Ereignisse und Sicherheitsvorfälle“ auf „abgeschlossen“ gesetzt werden, da alles Notwendige in diesem Modul getan wurde.)

Risikomanagement

Das neue „Risikomanagement“ und das Modul „Datenschutz-Folgenabschätzung“ sind sich sehr ähnlich. Dieses Modul soll zur Risikobeurteilung und Risikobehandlung im ISMS genutzt werden (bspw. Ereignis und Sicherheitsvorfälle oder auch Ergebnisse aus Audits und anderen Risikoeingaben).

1. Risikomanagement anlegen

2. Ursprung festlegen und mit Datensatz verknüpfen

Es können bestehende Datensätze verknüpft werden (aus den Geschäftsprozessen oder den Ereignissen), oder auch eigene Ursprünge (bspw. Audits) hinzugefügt werden.

3. Risiken definieren

Hier müssen eventuell eintretende Risiken genannt und beurteilt werden. Dazu können unter dem Reiter „Risiko“ Risikobeurteilungen angelegt und ausgefüllt werden. Hier wird die Risikomatrix, welche zu Beginn in den Risikoeinstellungen angelegt wurde, verwendet.

4. Risikobehandlung

Hier können die zuvor festgelegten Risiken behandelt werden, wobei nach eventuell eingeführten Maßnahmen eine Risikoanalyse erneut durchgeführt werden kann. Dadurch lässt sich in der Risikobeurteilung das Risiko reduzieren.

5. Prüfung

Bei der Prüfung in diesem Modul handelt es sich um eine Akzeptanzbewertung des Risikos.

ISMS-Compliance

Das Modul „ISMS-Compliance“ dient, ähnlich wie die „Datenschutzgrundsätze“, als Dokumentation und Nachweis, dass ein Unternehmen ein ISMS führt und stellt die Umsetzung von Anforderungskatalogen (z.B. dem Standard des VDA ISA) dar.

1. Neuen Anforderungskatalog erfassen

2. Datensätze verknüpfen

Es können im Reiter „Compliance“ in den verschiedenen Abschnitten auch technische und organisatorische Maßnahmen verknüpft werden, womit ausgewählt wird mithilfe welcher Maßnahmen jener Abschnitt umgesetzt wird.

3. Umsetzungsstand anpassen (Prozentzahl)

4. Kapitel hinzufügen, wenn gewünscht

5. Prozentzahl in der Übersicht passt sich entsprechend aus allen Abschnitten an

Fragen + Antworten

Weitere Funktionen, die wir für die Compliance + ISMS Erweiterung umsetzen werden:

- Auswahl weiterer Anforderungskataloge (Standards) im Modul "ISMS-Compliance", welche teilweise kostenpflichtig sein können: DIN EN ISO 27001, CISIS12, VdS10000, BSI IT-Grundschutz
- Business Continuity Management mit Ausfall- und Wiederherstellungszeiten in den Geschäftsprozessen
- Verknüpfen von Aufgaben mit den neuen Modulen
- Optimierung von Word- und CSV-Exporten
- Optimierung von Filtern
- Löschen von Einträgen, wo bisher nicht möglich
- Lerneinheiten für KI-Kompetenz sowie NIS-2 bedingte Risiken für Geschäftsführer
- Überarbeitung der Dashboard-Kacheln auf der Startseite
- Optische Verbesserungen der Berichtsausgabe im Word-Format und Integration der Compliance + ISMS Module

Weitere Hilfsmaterialien

Weitere Dokumente und Muster zur Informationssicherheit, KI-Richtlinie oder Regelwerke für ein Datenschutz- und Informationssicherheitsmanagementsystem finden Sie auch bei uns im Shop unter <https://shop.audatis.de>

Kontakt bei weiteren Fragen



Mike Moroncini

Sales

sales@audatis.de

Tel. 05221 872 92 17



Lea Knicker



Sebastian Kühnemund

Customer Success Team

support@audatis-manager.de

Tel. 05221 872 92 40

Vielen Dank

www.audatis.de



audatis Group auf XING



audatis Group auf LinkedIn



audatis Dialog auf YouTube



audatis Group auf Facebook

